

XWorm Malware Report

XWorm — Malware Analysis Report

Published: 2026-06-01 | TLP: CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

1. Executive Summary

XWorm is the highest-ranked family in the current ANY.RUN tracker, appearing as a Windows RAT sold as malware-as-a-service. It is operationally dangerous because it combines remote access, credential theft, surveillance, plugin delivery, persistence, and commodity distribution patterns that make it accessible to low-skill and mid-skill operators. Current public sandbox telemetry shows recent XWorm activity as of late May 2026, with repeated use of dynamic DNS, tunneling services, Pastebin-like configuration locations, Telegram-related artifacts, registry persistence, and auto-start behavior.

Business risk is high. A single XWorm infection should be treated as potential credential compromise plus hands-on-keyboard access. Priority response should include host isolation, credential reset for the affected user, browser/session-token invalidation, mailbox review, and hunting for additional payloads.

2. Sample Metadata

Field	Assessment
Family	XWorm
Type	Remote Access Trojan / stealer-capable RAT
Platform	Windows
First seen	ANY.RUN lists 2022-07-15
Recent activity	ANY.RUN lists last seen 2026-05-25 on the family page; tracker showed 483 tasks in the previous seven days
Common delivery	Phishing, malicious attachments, scripts, copied commands, staged payloads
Confidence	High for family behavior; medium for current infrastructure because public IOCs rotate quickly

3. Source Review & Confidence

Claim	Source	Date	Confidence	Notes
XWorm is a RAT sold as MaaS with credential/file theft, MetaMask/Telegram targeting, and user tracking.	ANY.RUN XWorm overview	Accessed 2026-06-01	High	Primary sandbox/intel source.
XWorm ranked first in the current ANY.RUN tracker.	ANY.RUN Malware Trends Tracker	Accessed 2026-06-01	High	Ranking reflects ANY.RUN public submissions.
XWorm has been described as modular and actively maintained in 2025-2026 reporting.	TechNadu / TechRadar summaries citing vendor research	2025-2026	Medium	Secondary reporting; validate against samples.

Claim	Source	Date	Confidence	Notes
RAT and stealer categories remain dominant in 2025-2026 malware telemetry.	ANY.RUN Malware Trends Report 2025	2026-01-20	High	Strategic context.

3.1 Expanded Source Matrix

Source	Contribution	Confidence
ANY.RUN Malware Trends Tracker	Current prevalence ranking and recent task volume.	High for tracker context
ANY.RUN XWorm family overview	Family description, first/last seen dates, representative samples, infrastructure hints.	High
ANY.RUN XWorm C2 communication analysis	C2 behavior, traffic expectations, and sandbox-derived communication notes.	High
KPMG XWorm V6.0 advisory	Version evolution, modular plugin direction, persistence, stealth, and JavaScript/PowerShell delivery notes.	Medium / High
CybaNetix technical report	Variant-level technical analysis, encoded configuration notes, TCP C2 behavior, and historical exploit-delivery references.	Medium
ANY.RUN Malware Trends Report 2025	Strategic context for stealer/RAT prevalence.	High
TechNadu / secondary reporting	Detection trend context and ecosystem activity.	Medium

3.2 Evidence Ledger

Claim	Evidence	Confidence	Analyst Note
XWorm is actively used as a MaaS RAT/stealer.	ANY.RUN family page and recent public sandbox task volume.	High	Public sandbox volume can be biased toward submitted samples but still indicates active use.
XWorm versions have evolved toward modular plugins and stronger stealth.	KPMG V6.0 reporting and variant analysis.	Medium / High	Version-specific claims require sample validation before applying to every XWorm case.
XWorm commonly uses dynamic DNS, paste/config hosting, and tunneling services.	ANY.RUN observed indicators and family behavior.	Medium	These services are dual-use; use process and execution context.

Claim	Evidence	Confidence	Analyst Note
XWorm infection implies credential risk and interactive operator risk.	RAT capability plus stealer functionality.	High	Response should include identity containment, not only endpoint cleanup.

4. Payload Variants and Delivery

XWorm is usually delivered through multi-stage chains rather than direct execution alone. Common delivery paths include phishing emails, archive attachments, malicious scripts, fake installers, Pastebin-hosted configuration, GitHub or file-sharing staging, and dynamic DNS/tunneling infrastructure. Its MaaS nature means different operators may package, obfuscate, and stage it differently.

4.1 Ecosystem and Version Notes

XWorm is best understood as a commodity RAT family with stealer functionality and an operator ecosystem rather than a single campaign. Public reporting describes an evolution from earlier 5.x builds toward 6.x builds with stronger modularity, plugin support, and stealth. This matters defensively because detections based only on static strings or a single builder version will age quickly.

The operator model also explains why delivery chains vary. One incident may show phishing attachments and dynamic DNS, while another may use JavaScript, PowerShell, Telegram bot artifacts, paste-hosted configuration, or tunnel services. The stable defender view is the behavior sequence: user execution or scripted loader, user-writable payload, persistence, configuration/C2 retrieval, surveillance, credential access, and potential plugin delivery.

5. Infection Chain Analysis

1. User receives a lure or downloads a staged file.
2. Script, archive, or executable launches a loader or XWorm client.
3. Malware performs environment checks and may query IP/geolocation services.
4. Persistence is established through registry autorun or startup mechanisms.
5. Client retrieves configuration or C2 data, often via dynamic DNS, Pastebin-style URLs, or tunneling services.
6. RAT capability enables command execution, plugin loading, credential access, clipboard monitoring, screenshots, and file theft.

6. Technical Analysis

Key behaviors to prioritize:

- Remote command execution and plugin loading.
- Credential theft from browsers and wallet-related data.
- Telegram and MetaMask account targeting.
- Registry-based auto-start and startup persistence.

- Pastebin or dynamic text-hosted C2 configuration.
- Dynamic DNS and tunnel relay usage.
- Sandbox and IP/geolocation checks.

6.1 Static Analysis Expectations

When a sample is available, prioritize:

- PE metadata, compiler/runtime, timestamp anomalies, and signer state.
- Packer or obfuscator indicators.
- Embedded C2 values, ports, campaign IDs, mutexes, plugin names, Telegram bot tokens, paste URLs, and dynamic DNS strings.
- Crypto or encoding routines used to protect configuration.
- Imports and API use for persistence, screen capture, clipboard access, credential theft, process injection, and network communication.
- Anti-analysis checks, including VM, sandbox, debugger, geolocation, and sleep behavior.

6.2 Dynamic Analysis Expectations

In a sandbox or lab, collect:

- Full process tree from initial lure to payload.
- Registry Run keys, startup folder writes, scheduled tasks, and dropped scripts.
- DNS and connection telemetry, especially dynamic DNS, tunneling, paste/config services, and Telegram-related traffic.
- File-system changes under %APPDATA%, %TEMP%, %PUBLIC%, and startup locations.
- Clipboard, screenshot, browser credential, wallet, and Telegram/MetaMask access events.
- Any plugin retrieval or follow-on payload execution.

7. Indicators of Compromise

7.1 Indicator Summary

Indicator Class	Count	Confidence	Recommended Use
SHA256 hashes	5 representative	High	Exact-match sweep only.
IP addresses	5 representative	Medium	Hunt and enrich before blocking.
Domains	8 representative	Medium / Low	Contextual hunt; many are dual-use.
URLs	3 representative	Medium	Hunt proxy/download telemetry.
Host indicators	Behavioral	High	Best detection value.

7.2 File Hashes

Type	Indicator	Confidence	Handling
SHA256	a69841a608fc2a280d501c4e42ae6c6ce7a2cd5bd0db480dcce9df89a78f739e	High	Sweep EDR; validate sample context.
SHA256	89b201e36df550b503207a85041059f4037787f39eec5045fe8c579e42e82814	High	Exact match only.
SHA256	4584fbee1219e5c5a366d02c35819f331cfadd404992f271183068de436d01	High	Exact match only.
SHA256	8fcec22a97275f5889d349dfa96295e0b95ab8597339ae6aa46d21a666ebcdb0	High	Exact match only.
SHA256	4a9f7a8a84f98529ffa36bdd88462fe3cea034756b70acfe00eef4b63a02e46	High	Exact match only.

7.3 Network Indicators

Type	Indicator	Confidence	Handling
IP	213.152.162.15	Medium	Enrich for current ownership and passive DNS.
IP	193.161.193.99	Medium	Hunt recent connections.
IP	46.183.222.61	Medium	Hunt recent connections.
IP	84.200.69.80	Medium	Hunt recent connections.
IP	194.5.98.207	Medium	Hunt recent connections.
Domain	0.tcp.ngrok.io	Low	Dual-use; require process and command-line context.
Domain	serveo.net	Low	Dual-use tunnel service.
Domain	portmap.io	Low	Dual-use tunnel service.
Domain	helloworlds.duckdns.org	Medium	Hunt DNS/proxy telemetry.
Domain	needforrat.hopto.org	Medium	Hunt DNS/proxy telemetry.

7.4 URL / Config Indicators

Type	Indicator	Confidence	Handling
URL	https://pastebin.com/raw/2L3vs8UY	Medium	Hunt downloads; verify content before blocking broad service.
URL	https://pastebin.com/raw/S0j6LcjH	Medium	Hunt downloads.
URL	https://pastebin.com/raw/iVUhhYa8	Medium	Hunt downloads.

7.5 Host Indicators

Type	Indicator	Confidence	Notes
Registry	Run key or auto-start entry pointing to suspicious user-profile executable	High	Behavioral detection.
Process	Unsigned executable making tunnel/DNS/Pastebin connections	High	Correlate with network.
Behavior	Clipboard monitoring, screenshots, plugin retrieval	High	EDR behavior.

7.6 IOC Usage Guidance

Use hashes for exact sample matching. Treat ngrok, serveo, portmap, Pastebin, and dynamic DNS as weak standalone indicators because they are legitimate or shared services. Strong confidence comes from process lineage, suspicious persistence, user-profile execution, and outbound connections to these services from unknown binaries.

7.7 Infrastructure Analysis

XWorm infrastructure should be scored by confidence:

- High: extracted C2 host/port from a confirmed sample or memory.
- Medium: domain/IP contacted by the suspicious process during detonation.
- Low: shared services such as ngrok, portmap, serveo, Pastebin, Telegram, or generic dynamic DNS without process context.

Hunt pivots should include passive DNS, first-seen dates, certificate reuse, ASN/hosting concentration, URL paths, Telegram bot identifiers, and repeated panel/config naming.

8. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1204.002	User Execution: Malicious File	Common phishing/archive execution path.
T1059.001	PowerShell	Scripted loaders and command execution.
T1547.001	Registry Run Keys / Startup Folder	Auto-start persistence observed in sandbox tags.
T1113	Screen Capture	RAT surveillance capability.
T1056.001	Keylogging	RAT/stealer behavior.
T1005	Data from Local System	File theft.
T1071.001	Web Protocols	HTTP/HTTPS staging and C2.
T1105	Ingress Tool Transfer	Plugin and payload retrieval.

9. Detection Engineering

Sigma - Suspicious User-Profile RAT Persistence With Tunnel Config

```
title: Suspicious User Profile Executable Persistence With Tunnel Or Paste Config Access
id: 5bd9c556-316a-4c0d-8f52-xworm-000000000001
status: experimental
description: Detects suspicious user-profile executables establishing persistence and contacting common tunnel or paste services
references:
  - https://any.run/malware-trends/xworm/
author: Lost Boys Cyber
date: 2026-06-01
tags:
  - attack.persistence
  - attack.t1547.001
  - attack.command_and_control
  - attack.t1071.001
logsource:
  product: windows
  category: process_creation
detection:
  selection_path:
    Image|contains:
      - '\AppData\'
      - '\Temp\'
      - '\Users\Public\'
  selection_cli:
    CommandLine|contains:
      - 'pastebin.com/raw'
      - 'ngrok.io'
      - 'duckdns.org'
      - 'hopto.org'
      - 'portmap.io'
  condition: selection_path and selection_cli
falsepositives:
  - Developer tunneling tools and legitimate automation; tune by signer, parent process, and approved tool inventory.
level: high
```

KQL Hunt

```
DeviceNetworkEvents
| where Timestamp > ago(14d)
| where RemoteUrl has_any ("pastebin.com", "ngrok.io", "duckdns.org", "hopto.org", "portmap.io", "serveo.net")
| join kind=leftouter (
  DeviceProcessEvents
  | where Timestamp > ago(14d)
  | project DeviceId, InitiatingProcessFileName=FileName, InitiatingProcessCommandLine=ProcessCommandLine, InitiatingProcessId=ProcessId
) on DeviceId
| where InitiatingProcessFolderPath has_any ("\\AppData\\", "\\Temp\\", "\\Users\\Public\\")
```

YARA - XWorm-Like Config Artifacts

```
rule MAL_Win_XWorm_Like_Config_Strings {
  meta:
    author = "Lost Boys Cyber"
    date = "2026-06-01"
    description = "Hunts XWorm-like samples with tunnel, paste, and RAT configuration artifacts"
  strings:
    $s1 = "pastebin.com/raw" ascii wide
    $s2 = "ngrok.io" ascii wide
    $s3 = "duckdns.org" ascii wide
    $s4 = "sendPlugin" ascii wide
    $s5 = "savePlugin" ascii wide
  condition:
    uint16(0) == 0x5A4D and 3 of them
}
```

10. Threat Hunting

Hypothesis: If XWorm is present, a user-profile executable will establish persistence and contact dynamic DNS, tunnel, paste, or plugin-hosting infrastructure.

Hunt steps:

- Search for new autorun entries pointing to %APPDATA%, %TEMP%, or %PUBLIC%.
- Pivot from suspicious persistence to outbound connections.
- Review clipboard, screenshot, browser credential access, and crypto wallet access alerts.
- Identify whether any second-stage payloads were dropped after the initial RAT.

10.1 Additional Hunt Queries

SPL:

```
index=endpoint (process_path="*\\AppData\\*" OR process_path="*\\Temp\\*" OR process_path="*\\Users\\Public\\*")
("pastebin.com/raw" OR "ngrok.io" OR "duckdns.org" OR "hopto.org" OR "portmap.io" OR "serveo.net")
| stats earliest(_time) as firstSeen latest(_time) as lastSeen values(command_line) values(dest) by host user process_name
```

Suricata hunting concept:

Alert when an internal workstation process reaches paste/config hosting or tunnel domains shortly after new autorun creation.

11. Triage and Incident Response

1. Isolate the endpoint.
2. Preserve memory and volatile network data if feasible.
3. Collect autoruns, process trees, EDR timeline, browser credential access events, and outbound DNS/proxy logs.
4. Reset user credentials and invalidate browser/session tokens.
5. Review mailbox rules, OAuth grants, VPN logs, and RMM access.
6. Hunt for lateral movement and additional payloads.

12. Validation and Emulation

Validate detections with benign simulations first: create a lab executable/script in a user-profile path that contacts a controlled test domain matching approved patterns, then test registry autorun creation. Do not execute live malware outside an isolated malware lab.

13. Recommendations

Priority	Owner	Timeline	Action
Critical	SOC / IR	24 hours	Alert on suspicious autoruns from user-writable paths plus tunnel/paste/dynamic DNS connections.
High	IAM	24-72 hours	Reset credentials and revoke tokens after confirmed infection.

Priority	Owner	Timeline	Action
High	Endpoint Engineering	7 days	Block unsigned executables from %TEMP% and high-risk script execution where operationally feasible.
Medium	Awareness	30 days	Train users on fake installer and copied-command lures.

14. References and Refresh Notes

- ANY.RUN Malware Trends Tracker: <https://anyrun.de/malware-trends/>
- ANY.RUN XWorm overview: <https://any.run/malware-trends/xworm/>
- ANY.RUN XWorm C2 analysis:
<https://any.run/cybersecurity-blog/xworm-malware-communication-analysis/>
- ANY.RUN Malware Trends Report 2025: <https://any.run/cybersecurity-blog/malware-trends-2025/>
- TechNadu XWorm 2026 detection trend summary: <https://www.technadu.com/xworm-rat-dominates-the-malware-as-a-service-landscape-with-174-increase-in-detections/623244/>
- KPMG XWorm V6.0 advisory: <https://assets.kpmg.com/content/dam/kpmgsites/in/pdf/2025/10/kpmg-ctip-xworm-v6-0-14-oct-2025.pdf.coredownload.inline.pdf>
- CybaNetix XWorm technical analysis report:
<https://cybanetix.com/wp-content/uploads/2025/11/XWORM-Malware-Analysis-Report-1.pdf>
- Refresh this report monthly or after major XWorm builder/version changes.

14.1 Intelligence Gaps

- Exact builder version and configuration schema require sample extraction.
- Public infrastructure indicators rotate quickly and should not be used as long-lived blocklists without enrichment.
- Plugin inventory varies by operator and version.
- Telegram/tunnel/paste service usage requires careful false-positive handling.